Bitcode

Anti-Gaming — Threat Model & Defenses

Grounded in the implemented mint math and $BTD — Tokenomics (leftover-mint) · where this document and BITCODE_SPEC diverge, SPEC wins.

Premise. Bitcode converts measurements into money, so every measurement is an attack surface, and every attack is one of two frauds: **mint $BTD (or earn settlement) for knowledge volume that isn't real**, or **extract value without paying**. Design goal: make every attack cost more than it yields, with the cost enforced by tools and economics — never by an agent's judgment alone.

1 · Defense principles (the spine)

1 · Tool-authoritative value. Weight concentrates on execution, static, and provenance readings agents cannot move. No minting path should exist through agent-only readings.

2 · Economic cost everywhere. Deposits, Needs, and reads carry real cost (treasury take, gating/stakes) so probing and spam are priced, not just filtered.

3 · Fail-closed. Missing measurement, tripped gate, failed validation → no admit, no settlement, no mint. Absence of proof is never treated as proof.

4 · Shape the reduction. Zero-floor, padding-concavity, overlap-subadditivity, and monotonicity make whole attack classes unprofitable inside the math itself.

5 · Versioned evidence. Every reading carries reference versions + evidence roots; disputes replay measurements instead of arguing about them.

6 · Standing red team. The attacks below run as CI evals against the live measurement stack; a defense that isn't continuously tested is assumed broken.

2 · Attack catalog

Layer D — Deposit (fake or inflated supply).

ID	Attack	Defense
D1	Padding — LOC/function-splitting/dup blocks to inflate counts	Quantity weight capped; duplication-internal discount; semantic structure (dataflow depth) over token counts; padding-concavity in the reduction
D2	Scrape-and-redeposit — public or already-admitted code sold as new	originality vs REFERENCE_CORPUS@v + admitted-pack index (MinHash/winnowing — rename-proof); zero-floor on unoriginal volume
D3	Contamination farming — depositing data models already trained on	contamination vs REFERENCE_TRAINING_SETS@v + canary grep; discounts to ~0
D4	Secret/PII laundering — leaking value through “obfuscated” deposits	secret-safety / pii-exposure verified-detector hard gates, fail-closed
D5	Coverage theater — tests that execute but assert nothing	test-strength (mutation score) — kill mutants or the tests don't count
D6	Synthetic flood — mass AI-generated low-value packs	Detectors unreliable → don't gate on them; originality + difficulty floors, deposit cost, zero-floor fit make volume-without-knowledge unprofitable
D7	Sybil sellers — one corpus split across many identities	Corpus-level fingerprint clustering across sellers; contribution measured per material, not per identity

Layer M — Measurement (corrupt the instrument).

ID	Attack	Defense
M1	Prompt injection — pack content instructs the judge	Judges see source-safe descriptors only, never raw source; injection-pattern scan on descriptors; agent share capped
M2	Goodharting a metric — optimize a proxy, not the value	Many orthogonal kinds; weights recalibrated against realized outcomes; judge-rubric detail not fully public
M3	Judge drift/gaming — style-pleasing content inflates scores	Pinned judge versions, ensemble-median, variance published; quality share capped; anchored golden fixtures
M4	Fixture overfitting — tuning packs to known golden fixtures	Fixtures rotated + held out; private eval split (SWE-bench-Pro pattern)
M5	Reference poisoning — polluting corpus/index to look “original”	References versioned, curated, hash-pinned; admitted-pack index append-only
M6	Evidence forgery — disputing with fabricated artifacts	Evidence roots on-chain; disputes replay the measurement under pinned versions
M7	Dynamic-neediness injection — a Read Request adds unknown *-fit rows; unknown kinds default to weight 1 vs a static catalog summing to 1.0, dominating the re-normalized mean	Highest-priority patch (measurement §5-G3): whitelist dynamic kinds; cap dynamic share of Σw (≤ 0.3); default unknown to 0/skip, never 1

Layer R — Read (extract without paying).

ID	Attack	Defense
R1	Oracle extraction — free Needs as a code-search/ measurement oracle	Needs gated/priced (stake or fee); rate limits; fit results are scores, not source
R2	Overlap double-count — near-duplicate packs assembled in one basket	Joint basket measurement with overlap-subadditivity (marginal-novelty kind)
R3	Need-stuffing — a Need crafted to inflate a specific pack's fit	Fit anchored to substrate absolutes (design-target); Need schema validation; monotonicity audits
R4	Source reconstruction — many reads triangulating obfuscated source	Descriptor-only exposure; per-pack read telemetry; reconstruction-risk scoring on descriptors

Layer S — Settlement & token (mint fraud).

ID	Attack	Defense
S1	Wash-trade minting — buy your own pack to mint $BTD	Leftover-mint is the structural defense: electing $BTD forfeits the cash to treasury, so self-dealing = buying $BTD from the treasury at the measured price. Profitable only if measurement overvalues junk → reduces to D-layer integrity + P÷B drift monitoring
S2	Collusive over-measurement — a Need tailored to junk	Design-target: fit × substrate (not yet implemented — measurement §5-G1). Implemented backstops: needFit ≤ 1 ⇒ ≤ 1 BTD notional per settle (decayed, capped to remaining), fail-closed invalid readings, real cash per settle — fraud must be voluminous, therefore visible and expensive

S3	Contribution-split gaming — multi-seller packs claiming inflated shares	Contribution measured from the material (fingerprint/attribution), not self-declared; per-contributor btdBps election applies only to the measured share
S4	Issuance timing games — bunching settlements around decay steps	Linear residual decay (implemented) — no step boundaries to game; mint scaled at current issuance level

Layer I — Infrastructure.

ID	Attack	Defense
I1	Sandbox escape / poisoned build scripts in verification	Network-off containers, resource caps, syscall filtering; verification emits scores only
I2	Malicious pack content targeting buyers (backdoors)	SAST + dependency gates on admit; provenance integrity; “verified” badge never implies a security warranty without the hygiene pass

3 · The economics do the heavy lifting

Leftover-mint (S1). The only way to mint $BTD is to hand the corresponding cash to the treasury. Minting is purchasing at measured price, so mint fraud collapses into measurement fraud — one problem to defend, not two.

Zero-floor × substrate (design-target — the top SPEC candidate, not yet implemented). BTD = substrate(pack) × Σ w·fit would make unoriginal, unverified, or secret-tripping material multiply everything by ~0, forcing attackers to fake the hardest signals (execution, provenance), not the easiest (judge charm). Until it lands, the implemented backstops carry the load: ≤ 1 BTD per settle, linear residual decay, fail-closed invalid readings, cash-per-settle cost.

Priced probing. Deposits, Needs, and reads all cost something; every attack iteration is a paying customer of the system it's attacking.

4 · Red-team protocol (standing)

1 · Attack suite in CI. Implementations of D1–D7, M1–M4, M7, R2–R3 as fixtures; each release must keep every attack's measured yield below its cost.

2 · Quarterly adversarial sprint. Humans + agents attempt novel attacks against a staging Depository with the real measurement stack; findings become new suite entries.

3 · Drift monitors. P÷B ratio, issuance rate vs settlements, fit-score distributions, per-seller originality trends; alerts on anomalies before disputes arrive.

4 · Bounty. Pay for demonstrated mint-fraud or extraction paths (testnet), scaled to severity — cheaper than discovering them on mainnet.

5 · Open questions

#	Question
Q1	Need gating mechanics (R1): stake, fee, or reputation — and refund on legitimate reads?
Q2	How much of the judge rubric / weight vector is public? (Transparency vs M2 Goodharting — publish kinds and postures, hold exact weights?)
Q3	Reconstruction-risk (R4): a formal budget per pack (max reads / descriptor entropy), or monitored-only?
Q4	Dispute economics: who pays for a measurement replay, and is there slashing for frivolous disputes?
Q5	Sybil resistance (D7/S3): is seller identity ever verified, or is all defense material-level?

Advanced Engineered Software, Inc. · July 27, 2026 · Grounded in the implemented settle math · Promote gate/validation changes through the SPEC gate · Companions: Measurement — Master Document · $BTD — Tokenomics.